



电子科技大学
University of Electronic Science and Technology of China

计算机系统与网络安全技术

Technology of Computer System and Network Security

牛伟纳

计算机科学与工程学院（网络空间安全学院）

2025年3月18日星期二





目录



第7章：拒绝服务攻击

- 拒绝服务攻击
- 洪泛攻击
- 分布式拒绝服务攻击
- 基于应用的带宽攻击
- 反射攻击与放大攻击
- 拒绝服务攻击防范
- 对拒绝服务攻击的响应





第七章 拒绝服务攻击

- 7.1拒绝服务攻击
- 7.2 洪泛攻击
- 7.3分布式拒绝服务攻击
- 7.4基于应用的带宽攻击
- 7.5反射攻击与放大攻击
- 7.6拒绝服务攻击防范
- 7.7对拒绝服务攻击的响应



拒绝服务攻击的定义（NIST）

- 拒绝服务是一种通过耗尽CPU、内存、带宽以及磁盘空间等系统资源，来阻止或削弱对网络、系统或应用程序的授权使用行为。
- 拒绝服务攻击是一种针对某些服务可用性的攻击。



作为DoS攻击对象的资源

网络带宽

- 与连接服务器和Internet的网络链路的容量相关
- 对于大部分组织来说，网路带宽指的是连接到其网络服务提供商（ISP）的链路容量

系统资源

- 针对系统资源的DoS攻击一般是通过过度加载或者使系统网络处理程序崩溃来实现攻击

应用资源

- 针对特定应用服务程序如Web服务器的攻击一般使用一定数量的合法请求，而每个合法请求都会明显地消耗掉服务器上的系统资源，那么就可以达到限制服务器响应其他合法用户请求的目的

拒绝服务攻击

说明DoS攻击的网络实例

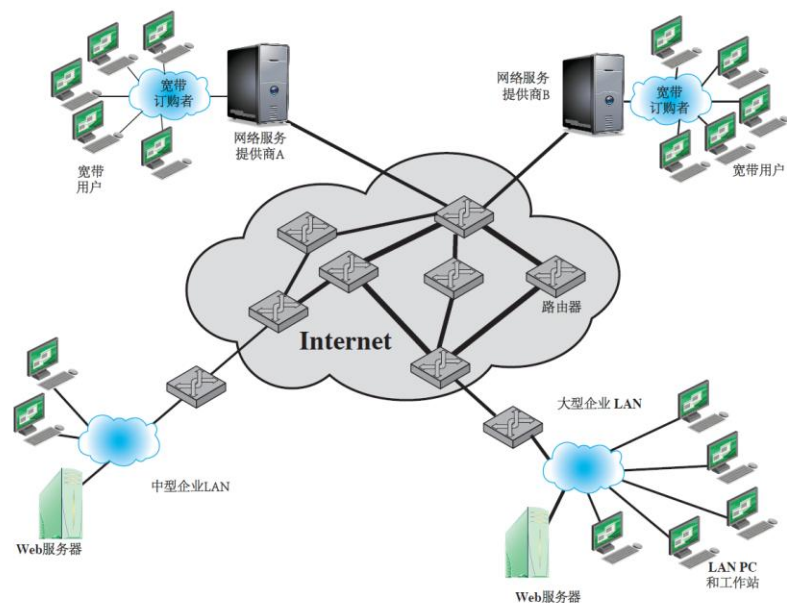
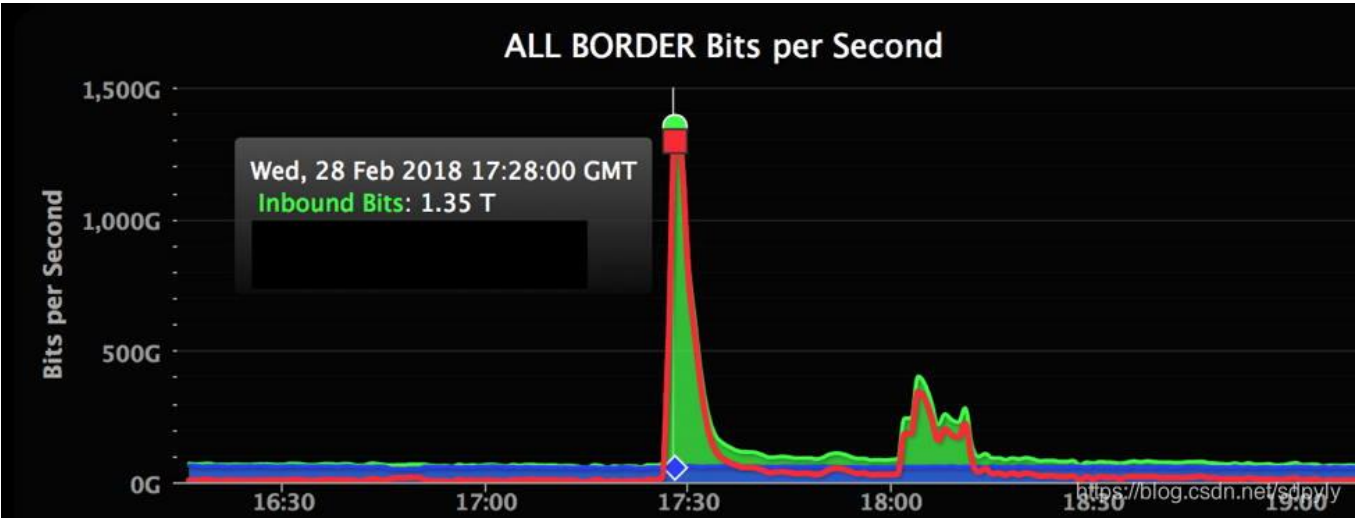


图 7.1 说明DoS攻击的网络实例

- 2018年2月28日，知名开发者平台GitHub突然被攻击，数据流量高达1.35Tbps。根据GitHub的报告，这些通信量被追溯到超过一千个不同的自治系统，数以万计的独立终端。在下图中，可见正常流量水平和DDoS攻击时流量的差异。



拒绝服务攻击

洪泛攻击

- 洪泛攻击的目标就是占据所有到目标组织的网络连接的容量
- 流量可以被路径上的高容量链路所处理，但是随着容量的减少，一些数据包将被丢弃
- 攻击源很容易被清楚地识别，除非使用一个欺骗的地址
- 网络性能受到明显地影响

拒绝服务攻击

源地址欺骗

- 使用伪造的源地址
 - 往往通过许多操作系统上的原始套接字接口来实现
 - 使攻击系统更难识别
- 攻击者会产生大量以目标系统为目的地址的报文
- 拥塞将导致路由器连接到最后的低容量链路
- 需要网络工程师专门从路由器上查询流量信息
- 发散反馈流量
 - 向未使用的IP地址发布路由，监控攻击流量

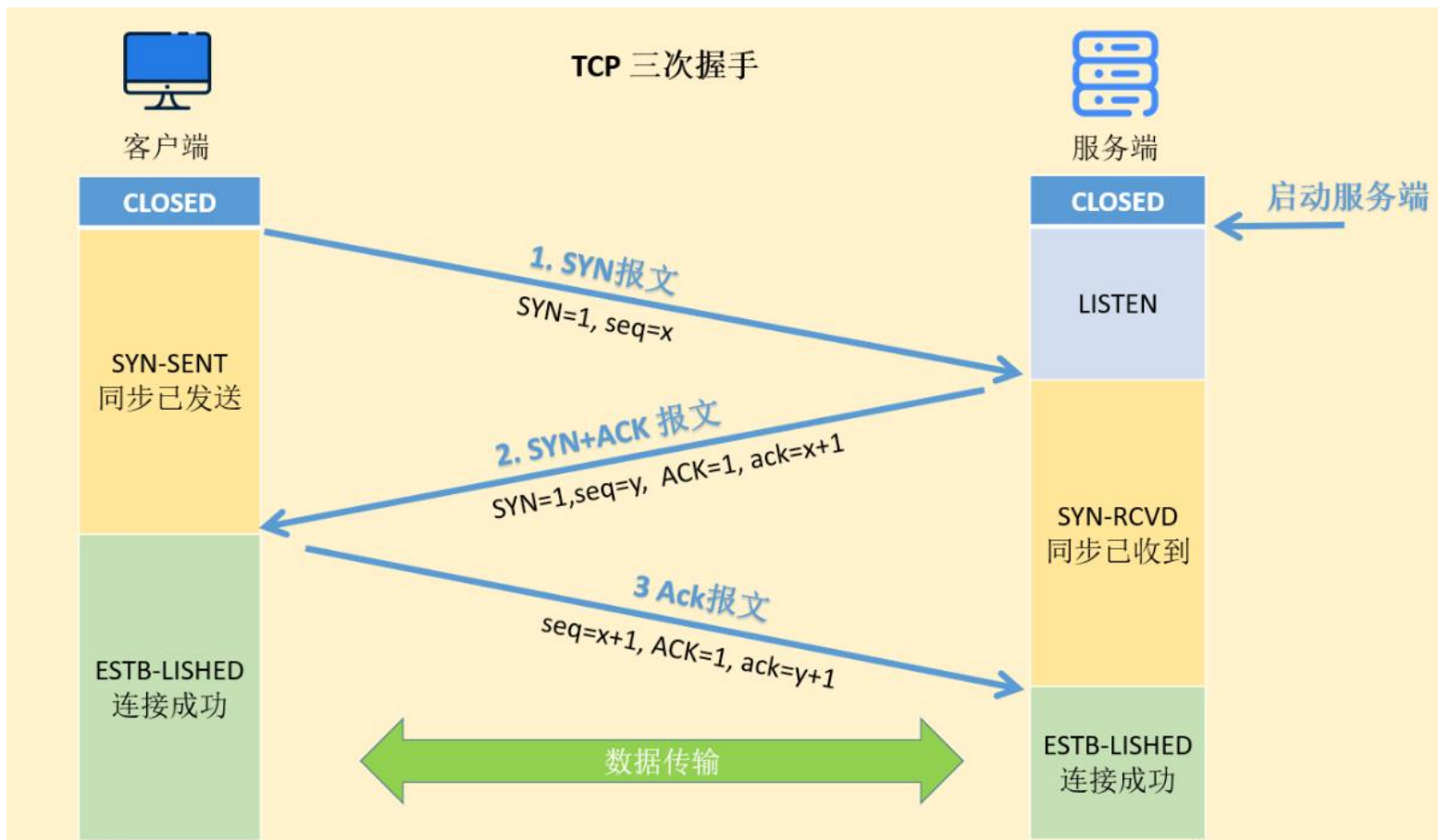
拒绝服务攻击

SYN欺骗

- 常见的经典DoS攻击
- 通过造成服务器上用于管理TCP连接的连接表溢出，从而攻击网络服务器响应TCP连接请求的能力
- 以后的合法用户的TCP连接请求将得不到服务器的响应，拒绝其访问服务器
- SYN欺骗攻击是针对系统资源的DoS攻击，具体地说就是针对操作系统上网络处理程序的攻击

拒绝服务攻击

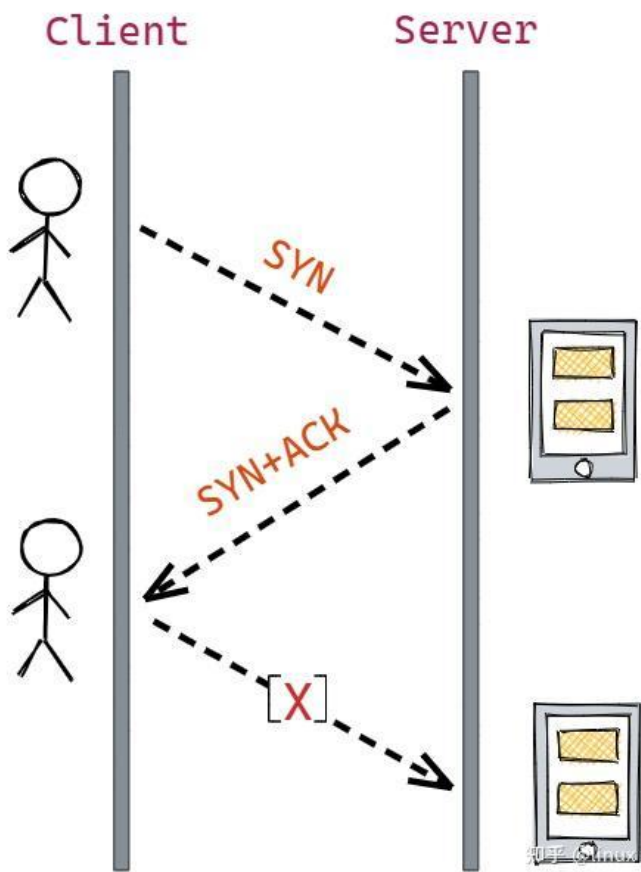
TCP三次连接握手



- 客户端需要发送一个 SYN包给服务端（包含了客户端初始化序列号），并且将连接的状态设置为SYN_SENT，这个过程由 connect()系统调用完成。
- 服务端接收到客户端发送过来的 SYN包后，回复一个 SYN+ACK包给客户端（包含了服务端初始化序列号），并且设置连接的状态为SYN_RCVD。
- 客户端接收到服务端发送过来的SYN+ACK包后，设置连接状态为ESTABLISHED（表示连接已经建立），并且回复一个ACK包给服务端。
- 服务端接收到客户端发送过来的ACK包后，将连接状态设置为ESTABLISHED（表示连接已经建立）。

拒绝服务攻击

TCP SYN欺骗攻击



如果客户端发送**SYN包**企图与服务端建立连接，但发送完**SYN包**后就不管，那会发送什么事情呢？

- 客户端发送一个 **SYN包**给服务端后就退出，而服务端接收到**SYN包**后，会回复一个**SYN+ACK包**给客户端，然后等待客户端回复一个**ACK包**。
- 但此时客户端并不会回复**ACK包**，所以服务端只能一直等待直到超时。服务端超时后，会重发**SYN+ACK包**给客户端，默认会重试5次，而且每次等待的时间都会增加（可以参考 TCP 协议超时重传的实现）。
- 另外，当服务端接收到**SYN包**后，会建立一个半连接状态的Socket。所以，当客户端一直发送**SYN包**，但不回复**ACK包**，那么将会耗尽服务端的资源，这就是 **SYN Flood 攻击**。



第七章 拒绝服务攻击

- 7.1 拒绝服务攻击
- 7.2 洪泛攻击
- 7.3 分布式拒绝服务攻击
- 7.4 基于应用的带宽攻击
- 7.5 反射攻击与放大攻击
- 7.6 拒绝服务攻击防范
- 7.7 对拒绝服务攻击的响应



洪泛攻击

基本概念

- 根据攻击所使用的网络协议不同，洪泛攻击可以划分为不同类型
- 其目的大都是使到服务器的链路超负荷
- 几乎任何类型的网络数据包都可以用来进行洪泛攻击

洪泛攻击

攻击类型

ICMP 洪泛

- 利用ICMP回送请求数据包的ping洪泛攻击
- 由于ping是一种很有用的网络分析工具，网络管理员一般允许ICMP回送请求数据包进入他们的网络，于是ICMP回送请求数据包很受攻击者的青睐

UDP 洪泛

- UDP数据包被发送到目标系统提供服务的端口上

TCP SYN 洪泛

- 向目标系统发送TCP报文
- 攻击的目标是报文总数，而不是系统代码



第七章 拒绝服务攻击

- 7.1 拒绝服务攻击
- 7.2 洪泛攻击
- 7.3 分布式拒绝服务攻击
- 7.4 基于应用的带宽攻击
- 7.5 反射攻击与放大攻击
- 7.6 拒绝服务攻击防范
- 7.7 对拒绝服务攻击的响应



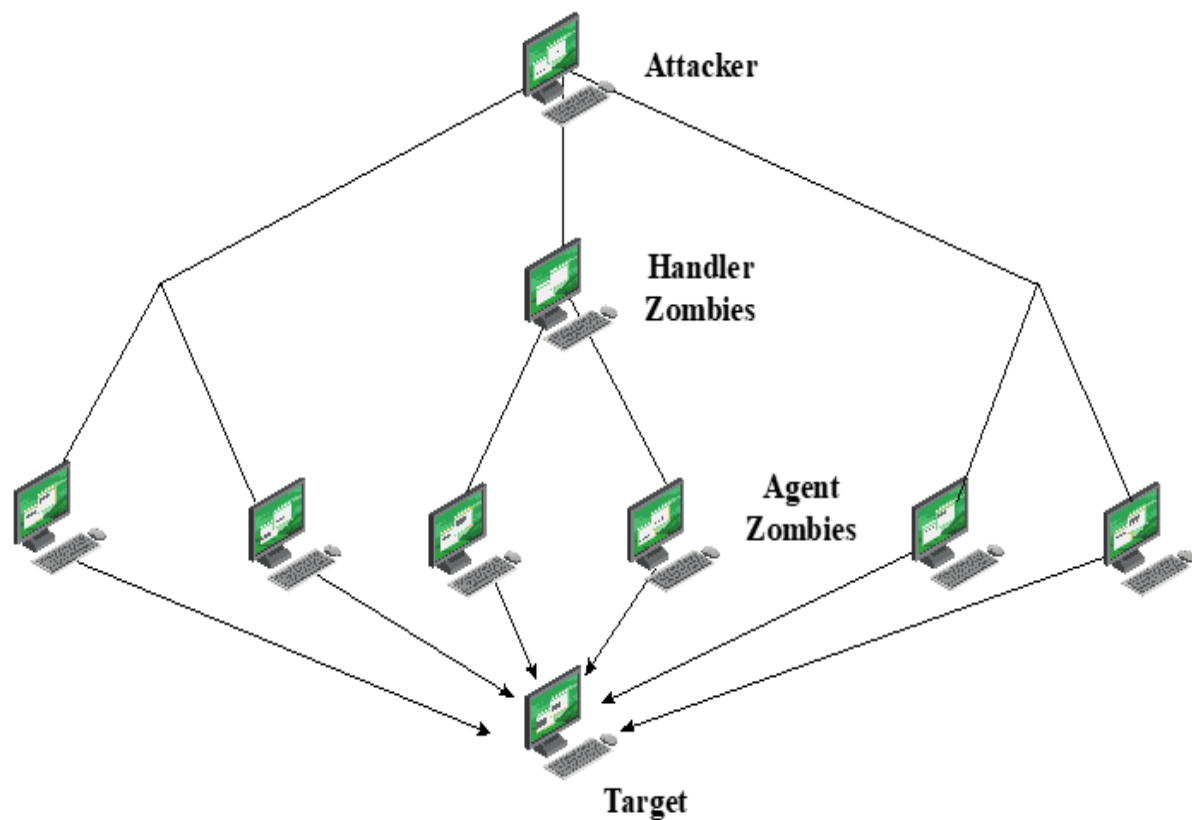
分布式拒绝服务攻击

分布式拒绝服务（DDoS）攻击

- 引入多机系统进行攻击
- 攻击者通过操作系统上或者某些常用应用程序的一些熟知的漏洞来获得访问这些系统（僵尸机）的权限，并在上面安装自己的程序
- 攻击者控制的大量僵尸机组合在一起就形成一个僵尸网络

分布式拒绝服务攻击

DDoS攻击体系结构



一个比较完善的DDoS攻击体系分成四大部分，分别是攻击者(attacker也可以称为master)、控制傀儡机(handler)、攻击傀儡机(demon，又可称agent)和受害者(victim)。第2部分的控制机只发布令而不参与实际的攻击，第3部分攻击傀儡机上发出DDoS的实际攻击包。



第七章 拒绝服务攻击

- 7.1 拒绝服务攻击
- 7.2 洪泛攻击
- 7.3 分布式拒绝服务攻击
- 7.4 基于应用的带宽攻击
- 7.5 反射攻击与放大攻击
- 7.6 拒绝服务攻击防范
- 7.7 对拒绝服务攻击的响应



基于应用的带宽攻击

SIP 洪泛

SIP(Session Initiation Protocol)是一个应用层的信令控制协议。IP服务提供商基于此可以对外提供包含语音、视频、聊天服务。该协议可以创建、修改和释放一个或多个参与者的会话(多媒体会议、IP电话、多媒体分发)。攻击者通过发送大量的invite消息到SIP服务器，导致被攻击SIP服务器分配大量的资源用以记录和跟踪会话，直到资源耗尽而无法响应合法用户的呼叫请求。

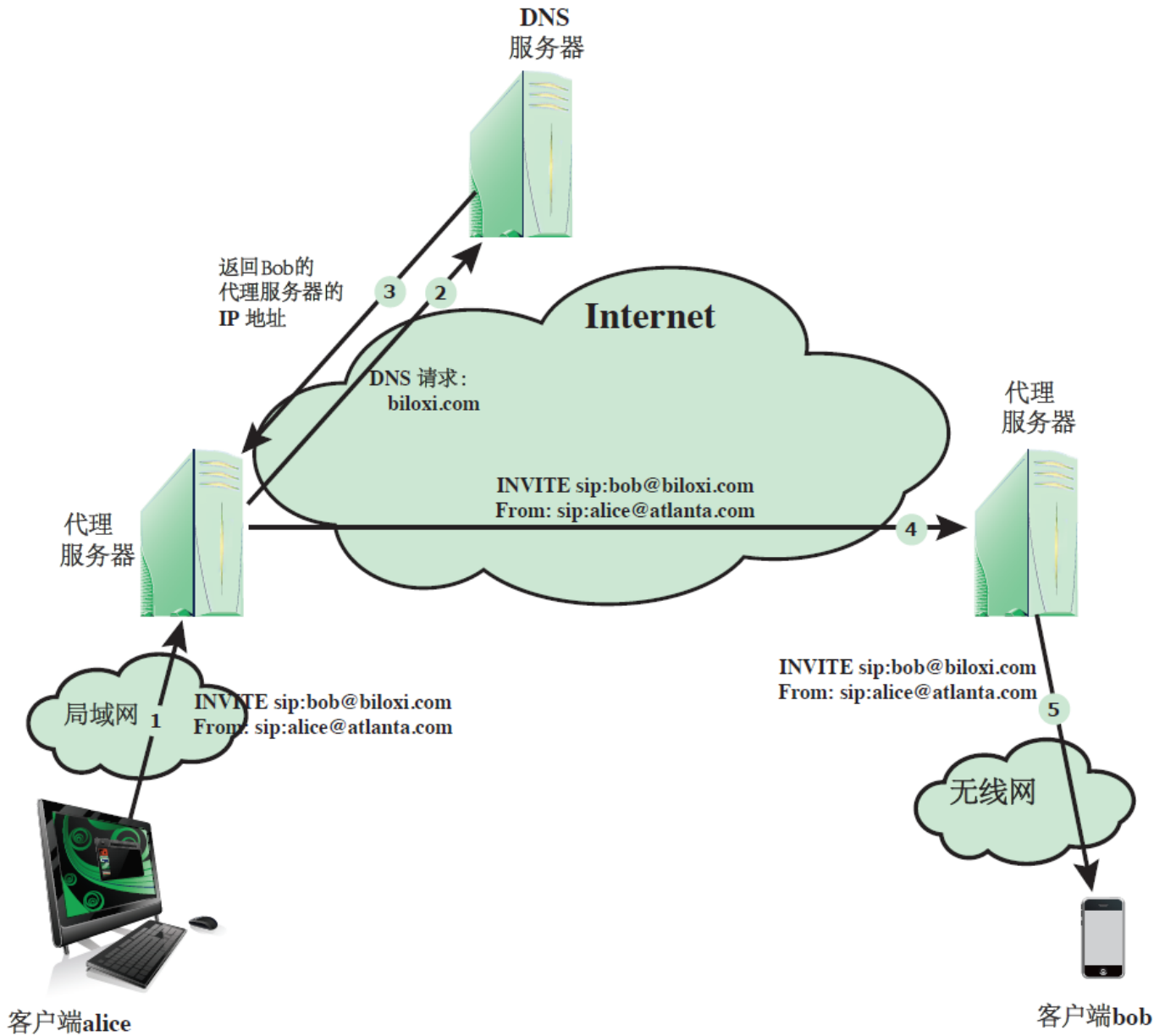


图 7.5 SIP INVITE 场景

基于应用的带宽攻击

基于HTTP的攻击

HTTP洪泛攻击

- 利用HTTP请求攻击Web服务器
- 消耗相当大的资源
- 爬虫
 - Bots从给定的HTTP链接出发，通过递归方式遍历给定Web服务器的所有链接

Slowloris

- 通过向Web服务器不停地发送不完整的HTTP请求，试图独占所有可用的请求处理线程
- 最终能耗尽所有Web服务器的连接能力
- 利用合法的HTTP流量
- 现有依赖特征检测的入侵检测和入侵防御手段无法识别出该攻击



第七章 拒绝服务攻击

- 7.1 拒绝服务攻击
- 7.2 洪泛攻击
- 7.3 分布式拒绝服务攻击
- 7.4 基于应用的带宽攻击
- 7.5 反射攻击与放大攻击
- 7.6 拒绝服务攻击防范
- 7.7 对拒绝服务攻击的响应



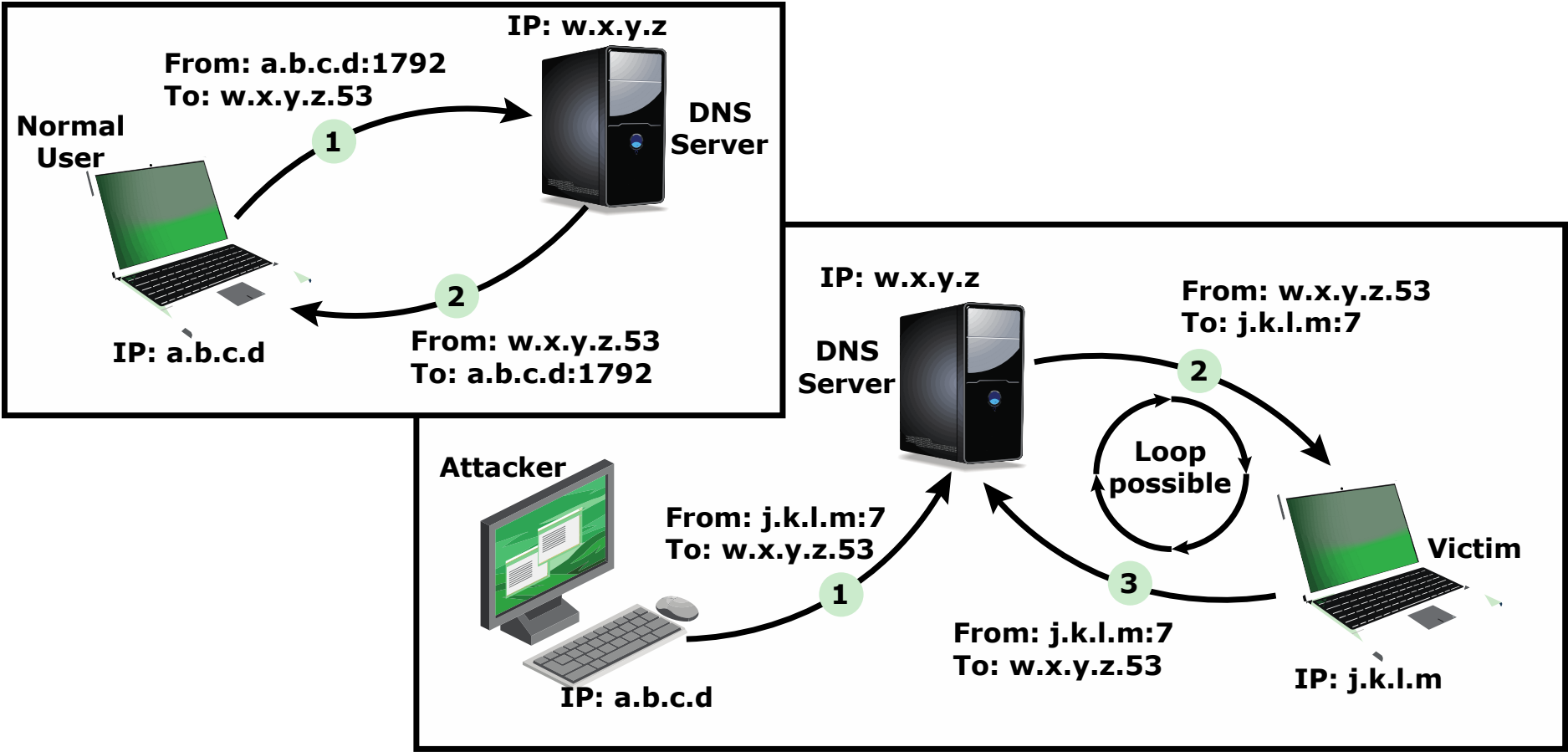
反射攻击与放大攻击

反射攻击

- 攻击者将其向攻击的目标系统地址作为数据包的源地址，并将这些数据包发送给中间媒介上的已知网络服务
- 当中间媒介响应时，大量的响应数据包会被发送给源地址所指向的目标系统
- 它能有效地使攻击从中间媒介反射出去（称为反射器）
- 目标是生成足够多的包使到目标系统的链路泛滥，而不惊动中间系统
- 对这些攻击的基本防御是阻断欺骗源报文

反射攻击与放大攻击

DNS反射攻击



反射攻击与放大攻击

DNS放大攻击

- 使用指向合法DNS服务器的报文作为中间系统
- 攻击者创建一系列DNS请求，其中包含目标系统的欺骗源地址
- 利用DNS行为将一个小请求转换为一个大得多的响应(放大)
- 目标被回应淹没了
- 对这种攻击的基本防御是防止使用欺骗的源地址

反射攻击与放大攻击

放大攻击

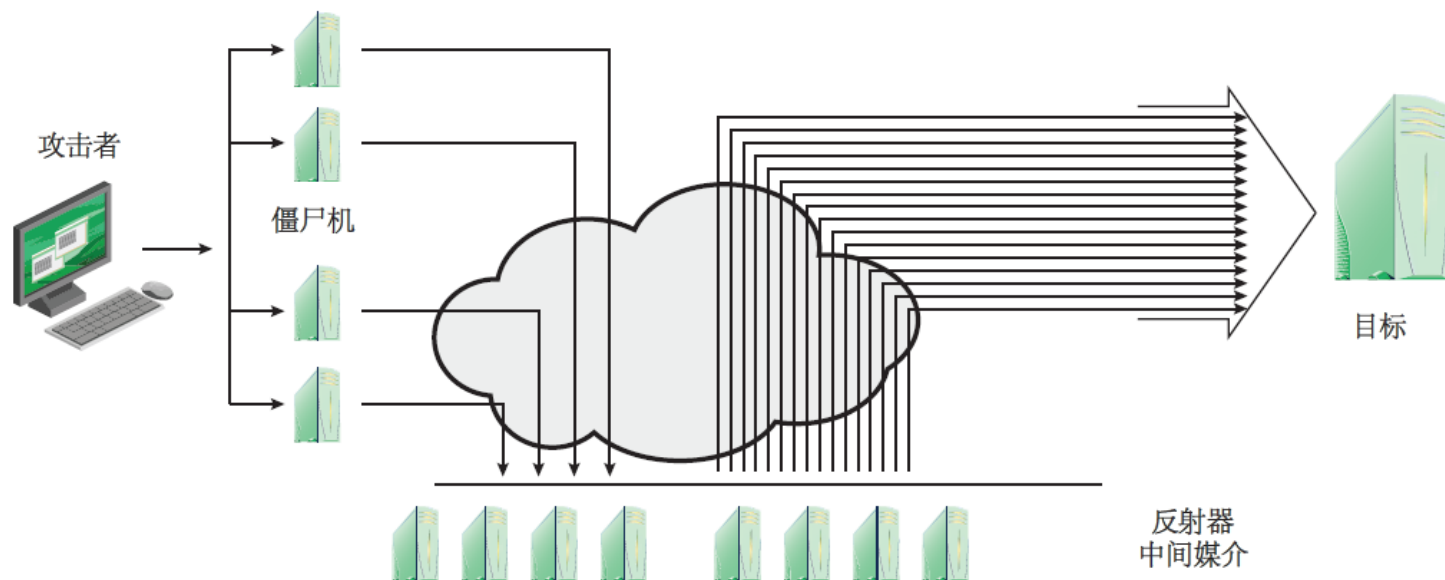


图 7.7 放大攻击



第七章 拒绝服务攻击

- 7.1拒绝服务攻击
- 7.2 洪泛攻击
- 7.3分布式拒绝服务攻击
- 7.4基于应用的带宽攻击
- 7.5反射攻击与放大攻击
- 7.6拒绝服务攻击防范
- 7.7对拒绝服务攻击的响应



拒绝服务攻击防范

DoS攻击防范

- DoS攻击不能完全预防
- DoS攻击的大流量可能是合法的
 - 对特定网站的高度宣传
 - 一个非常受欢迎的网站举行的活动

拒绝服务攻击防范

抵御DoS攻击的四道防线

攻击预防和先发制人机制（攻击前）

攻击检测和过滤（攻击）

攻击源回溯和识别（攻击时和攻击后）

攻击反应（攻击后）

拒绝服务攻击防范

DoS攻击防御

- 阻止虚假的源地址
 - 在尽可能靠近源的路由器上
- 过滤器可确保返回所声明的源地址路径是当前包正在使用的路径
 - 过滤器必须在流量离开ISP的网络之前或进入他们的网络的点应用
- 使用修改过的TCP连接处理代码
 - 对作为服务器初始序列号发送的cookie中的关键信息进行加密编码
 - 合法的客户端返回一个ACK报文，其中包含递增的序列号cookie
 - 当TCP连接表溢出时，从TCP连接表中删除不完整连接的条目

拒绝服务攻击防范

DoS攻击防御

- 阻止IP定向广播
- 阻止可疑的服务和组合
- 使用一种图形难题(验证码)形式来管理应用程序攻击，以区分合法的人工请求
- 良好的通用系统安全实践
- 当对性能和可靠性有要求时，可以使用镜像和复制服务器



第七章 拒绝服务攻击

- 7.1拒绝服务攻击
- 7.2 洪泛攻击
- 7.3分布式拒绝服务攻击
- 7.4基于应用的带宽攻击
- 7.5反射攻击与放大攻击
- 7.6拒绝服务攻击防范
- 7.7对拒绝服务攻击的响应



对拒绝服务攻击的响应

对DoS攻击的响应

- 良好的偶然事件响应计划
 - 联系ISP技术人员的详细信息
 - 需要向上游施加流量过滤
 - 如何响应攻击的详细信息
- 应已实现有关如何联系ISP反欺骗、定向广播和速率限制过滤器的技术人员的详细信息
- 理想情况下，应该使用网络监视器和IDS来检测和通知异常的流量模式

对拒绝服务攻击的响应

对DoS攻击的响应

- 识别攻击类型
 - 抓包分析
 - 设计过滤器阻断攻击流量
 - 或识别并纠正系统/应用程序错误
- ISP是否跟踪数据包流而确定源
 - 可能是困难和耗时的
 - 如果计划采取法律行动，这是必要的

对拒绝服务攻击的响应

对DoS攻击的响应

- 实施应急计划
 - 切换到备用备份服务器
 - 在具有新地址的新站点上委托新服务器
- 更新事故响应计划
 - 分析攻击和未来处理的响应良好的偶然事件响应计划



本章小结

- 7.1 拒绝服务攻击
 - 7.1.1 拒绝服务攻击的本质
 - 7.1.2 经典的拒绝服务攻击
 - 7.1.3 源地址欺骗
 - 7.1.4 SYN欺骗
- 7.2 洪泛攻击
 - 7.2.1 ICMP洪泛
 - 7.2.2 UDP洪泛
 - 7.2.3 TCP SYN洪泛
- 7.3 分布式拒绝服务攻击
- 7.4 基于应用的带宽攻击
 - 7.4.1 SIP洪泛
 - 7.4.2 基于HTTP的攻击
- 7.5 反射攻击与放大攻击
 - 7.5.1 反射攻击
 - 7.5.2 放大攻击
 - 7.5.3 DNS放大攻击
- 7.6 拒绝服务攻击防范
- 7.7 对拒绝服务攻击的响应

